

Threat Modelling SSD

Current Risk Summary report

Sun Mar 08 2026 14:49:07 GMT+0000 (Coordinated Universal Time)

Project description: No description

Filtered by: Critical risk High risk Medium risk Low risk Very Low risk

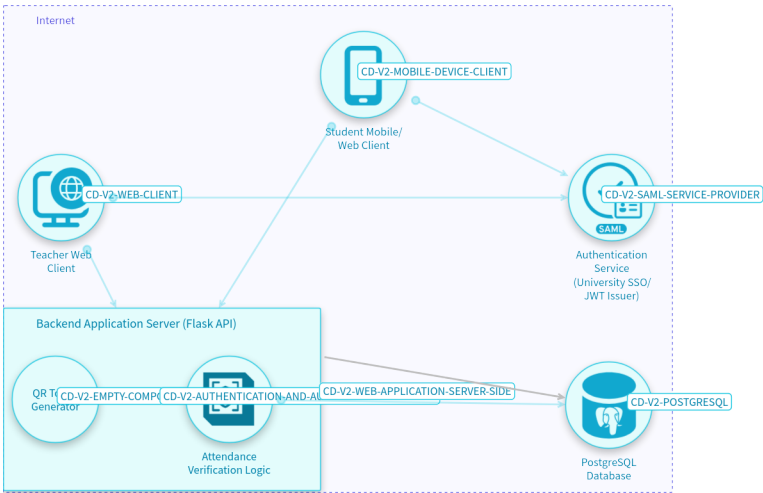
This report only includes threats that match the filters above.

Unique ID: emerald-underwriter-ec53e661

Owner: Zulqarnain Umar

Workflow state: Draft

Tags: No tags



Content menu

[Current risk summary](#)

[Components](#)

[Accepted Risks](#)

[Current Risks](#)

- [Attendance Verification Logic](#)
- [Authentication Service \(University SSO/JWT Issuer\)](#)
- [Backend Application Server \(Flask API\)](#)
- [PostgreSQL Database](#)
- [Student Mobile/Web Client](#)
- [Teacher Web Client](#)

Current Risk summary

Inherent risk description: The Inherent Risk before countermeasures were applied.
• **Risk Rating:** 70.66666412353516% High

The Current Risk description (the risk we are at now): The Current Risk is based on the current implementation status of the countermeasures and test results.
• **Risk Rating:** 19.39583396911621% Low

Projected Risk description: The Projected Risk is the level of risk that would be reached should the required countermeasures be implemented.
• **Risk Rating:** 15.22916698458105% Low

Components

- Attendance Verification Logic
Model questionnaire information:
 - Customer Data: How is it handled by this component? Processed
 - Customer Data: How is it handled by this component? Received by component
 - Do you have a policy and workflow for comprehensive logging and monitoring (tracking user activities and system events to detect suspicious behavior) in place? Yes, it is implemented
 - Do you have a secure access control mechanism (a way to ensure only authorized users can access certain parts of your application) in your workflow? Yes, it is implemented
 - Do you have rate limiting (a technique to control the number of requests a user can make) and proper resource management (efficient use of server resources) active in your module? Yes, it is implemented
 - Do you have secure configuration (ensuring settings are properly set to protect the application) and encryption standards (rules for converting data into a secure format) enforced in your project? Yes, it is implemented
 - Do you thoroughly validate and sanitize user input (checking and cleaning data provided by users to prevent harmful code or data from causing issues)? Yes, it is implemented
 - Does this component handle personally identifiable information from citizens of the European Union? No
 - Does this component have to be CCPA-compliant? No
 - Personally Identifiable Information: How is it handled by this component? Processed
 - Personally Identifiable Information: How is it handled by this component? Received by component
- Authentication Service (University SSO/JWT Issuer)
Model questionnaire information:
 - Customer Data: How is it handled by this component? Stored
 - Customer Data: How is it handled by this component? Processed
 - Customer Data: How is it handled by this component? Sent from component
 - Customer Data: How is it handled by this component? Received by component
 - Does this component handle personally identifiable information from citizens of the European Union? No
 - Does this component have to be CCPA-compliant? No
 - Is multi-factor authentication in place for the SAML service provider? Yes, it is implemented
 - Is the TLS/SSL encryption currently set up for all communication channels? Yes, it is implemented
 - Is the input sanitization and validation process already in place? Yes, it is implemented
 - Is the mechanism for session expiration, secure logout, and token revocation in place? Yes, it is implemented
 - Is the storing of assertions securely in place at the moment? Yes, it is implemented
 - Is the thorough validation of all assertions from a trusted Identity Provider currently conducted in your system? Yes, it is implemented
 - Is the trust establishment with Identity Providers using secure methods like mTLS and proper certificate validation already in place? Yes, it is implemented
 - Is timestamp-based validation and one-time use tokens presently in action to guard against replay attacks? Yes, it is implemented
 - Is timestamp-based validation and one-time use tokens presently in action to guard against replay attacks? Not sure
 - Personally Identifiable Information: How is it handled by this component? Stored
 - Personally Identifiable Information: How is it handled by this component? Processed
 - Personally Identifiable Information: How is it handled by this component? Sent from component
 - Personally Identifiable Information: How is it handled by this component? Received by component
- Backend Application Server (Flask API)
Model questionnaire information:
 - Customer Data: How is it handled by this component? Processed
 - Customer Data: How is it handled by this component? Sent from component
 - Customer Data: How is it handled by this component? Received by component
 - Does this component handle personally identifiable information from citizens of the European Union? No
 - Does this component have to be CCPA-compliant? No
 - Is implementation of prepared statements and user input validation in place? Yes, it is implemented
 - Is logging and monitoring for crucial actions currently enabled and functioning in the system? Not sure
 - Is logging and monitoring for crucial actions currently enabled and functioning in the system? Yes, it is implemented
 - Is the MFA enforcement, secure cookie usage and session invalidation currently in practice? Yes, it is implemented
 - Is the XML parser configured to disallow external entities and DTD processing? Yes, it is implemented
 - Is the dynamic content properly escaped/encoded and is the Content Security Policy configured? Yes, it is implemented
 - Is the measure to block or validate all outbound requests currently in place? Yes, it is implemented
 - Is the multi-step validation process for critical transactions currently in place? Yes, it is implemented
 - Is the procedure for disabling unused services, removing default accounts, and applying security updates in place? Yes, it is implemented
 - Is the process of checking user roles and permissions on every request currently applied in the system? Yes, it is implemented
 - Is the process of performing software composition analysis and patching outdated libraries currently in place? Yes, it is implemented
 - Is the protocol TLS in use for communication and stored data encrypted robustly? Yes, it is implemented
 - Is the use of secure data formats and strict whitelisting for deserialization in place? Yes, it is implemented
 - Personally Identifiable Information: How is it handled by this component? Processed
 - Personally Identifiable Information: How is it handled by this component? Sent from component
 - Personally Identifiable Information: How is it handled by this component? Received by component
- PostgreSQL Database
Model questionnaire information:

- Customer Data: How is it handled by this component? Stored
- Customer Data: How is it handled by this component? Processed
- Customer Data: How is it handled by this component? Received by component
- Do you apply regular security patches and minor version updates to the PostgreSQL database engine? Yes, it is implemented
- Does PostgreSQL require MFA for database access via an external Identity Provider? No, and this is not applicable
- Does this component handle personally identifiable information from citizens of the European Union? No
- Does this component have to be CCPA-compliant? No
- Is PostgreSQL database file permissions setting enforced and updated regularly in your current system? Yes, it is implemented
- Is PostgreSQL routinely updated to its latest secure version in the current system? Yes, it is implemented
- Is auditing and logging of all PostgreSQL database activities currently configured and active? Yes, it is implemented
- Is data at rest encrypted using TDE, LUKS, or cloud provider managed encryption? Yes, it is implemented
- Is rate limiting and resource throttling active and regularly updated in PostgreSQL? Yes, it is implemented
- Is the PostgreSQL configuration hardened and network access restricted currently? Yes, it is implemented
- Is the TLS encryption enforced for all connections to PostgreSQL? Yes, it is implemented
- Is the robust authentication and role-based access control currently in effect for PostgreSQL? Yes, it is implemented
- Is the secure backup procedure with encryption and access controls for PostgreSQL currently implemented? Yes, it is implemented
- Is the use of parameterized queries and validation of inputs in place for PostgreSQL to prevent SQL injection attacks? Yes, it is implemented
- Personally Identifiable Information: How is it handled by this component? Stored
- Personally Identifiable Information: How is it handled by this component? Processed
- Personally Identifiable Information: How is it handled by this component? Received by component

• QR Token Generator

Model questionnaire information:

- Customer Data: How is it handled by this component? Processed
- Customer Data: How is it handled by this component? Sent from component
- Does this component handle personally identifiable information from citizens of the European Union? No
- Does this component have to be CCPA-compliant? No
- Personally Identifiable Information: How is it handled by this component? Processed
- Personally Identifiable Information: How is it handled by this component? Sent from component

• Student Mobile/Web Client

Model questionnaire information:

- Customer Data: How is it handled by this component? Processed
- Customer Data: How is it handled by this component? Sent from component
- Customer Data: How is it handled by this component? Received by component
- Does this component handle personally identifiable information from citizens of the European Union? No
- Does this component have to be CCPA-compliant? No
- Is secure backup and data synchronization protocols implemented on all mobile devices currently? No, and this is not applicable
- Is secure data storage and device encryption configured and regularly updated on all mobile devices? No, and this is not applicable
- Is strong device authentication properly set up on all mobile devices? No, and this is not applicable
- Is the VPN usage and encrypted communication policy enforced and regularly updated on all mobile devices? No, and this is not applicable
- Is the configuration for automatic mobile OS updates currently implemented? No, and this is not applicable
- Is the mobile anti-malware solution deployed, updated regularly and managed through MDM tools? No, and this is not applicable
- Is the mobile anti-phishing protection currently deployed and regularly updated? No, and this is not applicable
- Is the policy of app store whitelisting and robust app vetting active and regularly updated? No, and this is not applicable
- Is the policy of regular app updates and conducting vulnerability scanning currently active? No, but it is required
- Is the remote wipe and tracking feature on all mobile devices active and regularly updated? No, and this is not applicable
- Personally Identifiable Information: How is it handled by this component? Processed
- Personally Identifiable Information: How is it handled by this component? Sent from component
- Personally Identifiable Information: How is it handled by this component? Received by component

• Teacher Web Client

Model questionnaire information:

- Customer Data: How is it handled by this component? Processed
- Customer Data: How is it handled by this component? Sent from component
- Customer Data: How is it handled by this component? Received by component
- Does this component handle personally identifiable information from citizens of the European Union? No
- Does this component have to be CCPA-compliant? No
- Is HTTPS enforced with strong TLS configurations for secure communication? Yes, it is implemented
- Is JavaScript sandboxing used to restrict script execution and prevent unsafe DOM manipulation? No, but it is required
- Is a JavaScript-based frame-busting technique in place to detect and block UI redressing attempts? No, but it is required
- Is sensitive data securely stored on the client side, or is storage prevented where unnecessary? Yes, it is implemented
- Personally Identifiable Information: How is it handled by this component? Processed
- Personally Identifiable Information: How is it handled by this component? Sent from component
- Personally Identifiable Information: How is it handled by this component? Received by component

Accepted Risks

No data

Current Risks

Component: Attendance Verification Logic

🔒 Use case: Elevation of Privilege CRT1. Threat name: Attackers gain unauthorized access or elevated privileges, e.g., via stolen credentials, cookies, or tokens Inherent risk: ⬆️ High Current risk: 🟢 Very Low Projected risk: 🟢 Very Low State: Mitigated CR1. Countermeasure name: Use secure access control mechanisms Status: IMPLEMENTED
🔒 Use case: Tampering CRT2. Threat name: Attackers inject malicious content, e.g., SQL queries, to manipulate or access data Inherent risk: ⬆️ High Current risk: 🟢 Very Low Projected risk: 🟢 Very Low State: Mitigated CR2. Countermeasure name: Input validation and sanitization Status: IMPLEMENTED
🔒 Use case: Information Disclosure CRT3. Threat name: Attackers intercept or eavesdrop on sensitive information during transmission Inherent risk: ⬆️ High Current risk: 🟢 Very Low Projected risk: 🟢 Very Low State: Mitigated CR3. Countermeasure name: Enforce secure configuration and encryption Status: IMPLEMENTED
🔒 Use case: Denial of Service CRT4. Threat name: Attackers use enumeration to discover valid user identifiers, potentially creating a Denial of Service (DoS) condition Inherent risk: ⬆️ High Current risk: 🟢 Very Low Projected risk: 🟢 Very Low State: Mitigated CR4. Countermeasure name: Rate limiting and proper resource management Status: IMPLEMENTED
🔒 Use case: Repudiation CRT5. Threat name: Lack of evidences of misuse due to insufficient logging Inherent risk: 🟡 Medium Current risk: 🟢 Very Low Projected risk: 🟢 Very Low State: Mitigated CR5. Countermeasure name: Create a policy and workflow for comprehensive logging and monitoring Status: IMPLEMENTED

Component: Authentication Service (University SSO/JWT Issuer)

🔒 Use case: Tampering CRT6. Threat name: Attackers can compromise assertion storage Inherent risk: 🔴 Critical Current risk: 🟢 Very Low Projected risk: 🟢 Very Low State: Mitigated CR6. Countermeasure name: Store assertions securely Status: IMPLEMENTED CRT7. Threat name: Attackers can exploit insufficient session management Inherent risk: 🔴 Critical Current risk: 🟢 Very Low Projected risk: 🟢 Very Low State: Mitigated CR7. Countermeasure name: Implement proper session expiration, logout, and token revocation mechanisms
--

- **Status:** IMPLEMENTED

CRT8. Threat name: Attackers can inject malicious assertions

- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR8. Countermeasure name:** Validate all assertions thoroughly
- **Status:** IMPLEMENTED

CRT9. Threat name: Attackers can perform man-in-the-middle (MITM) attacks

- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR9. Countermeasure name:** Use TLS/SSL encryption for all communication channels to ensure confidentiality and integrity of data in transit
- **Status:** IMPLEMENTED

Use case: Spoofing

CRT10. Threat name: Attackers can conduct phishing attacks

- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR10. Countermeasure name:** Implement multi-factor authentication (MFA)
- **Status:** IMPLEMENTED

CRT11. Threat name: Attackers can impersonate identity federation trust

- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR11. Countermeasure name:** Use secure methods for establishing trust with Identity Providers
- **Status:** IMPLEMENTED

Use case: Information Disclosure

CRT12. Threat name: Attackers can exploit cross-site scripting (XSS) vulnerabilities

- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR12. Countermeasure name:** Sanitize and validate all inputs
- **Status:** IMPLEMENTED

Use case: Repudiation

CRT13. Threat name: Attackers can replay SAML assertions

- **Inherent risk:** Critical
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR13. Countermeasure name:** Implement timestamp-based validation and one-time use tokens
- **Status:** IMPLEMENTED

Component: Backend Application Server (Flask API)

Use case: Information Disclosure

CRT14. Threat name: Attackers can abuse server-side requests

- **Inherent risk:** Medium
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR14. Countermeasure name:** Block or validate all outbound requests
- **Status:** IMPLEMENTED

CRT15. Threat name: Attackers can exploit insecure configurations

- **Inherent risk:** High
- **Current risk:** Very Low
- **Projected risk:** Very Low
- **State:** Mitigated
- **CR15. Countermeasure name:** Disable unused services, remove default accounts, and apply security updates
- **Status:** IMPLEMENTED

- CRT16. Threat name:** Attackers can exploit unsafe XML parsers
- **Inherent risk:** Critical
 - **Current risk:** Very Low
 - **Projected risk:** Very Low
 - **State:** Mitigated
 - **CR16. Countermeasure name:** Configure XML parsers to disallow external entities and DTD processing
 - **Status:** IMPLEMENTED

- CRT17. Threat name:** Attackers can intercept or leak sensitive data
- **Inherent risk:** Critical
 - **Current risk:** Very Low
 - **Projected risk:** Very Low
 - **State:** Mitigated
 - **CR17. Countermeasure name:** Use TLS for communications and protect stored data with encryption
 - **Status:** IMPLEMENTED

Use case: Elevation of Privilege

- CRT18. Threat name:** Attackers can bypass permissions
- **Inherent risk:** High
 - **Current risk:** Very Low
 - **Projected risk:** Very Low
 - **State:** Mitigated
 - **CR18. Countermeasure name:** Check user roles and permissions on every request
 - **Status:** IMPLEMENTED

- CRT19. Threat name:** Attackers can exploit vulnerable components
- **Inherent risk:** Critical
 - **Current risk:** Very Low
 - **Projected risk:** Very Low
 - **State:** Mitigated
 - **CR19. Countermeasure name:** Perform software composition analysis and patch outdated libraries
 - **Status:** IMPLEMENTED

Use case: Spoofing

- CRT20. Threat name:** Attackers can compromise sessions
- **Inherent risk:** High
 - **Current risk:** Very Low
 - **Projected risk:** Very Low
 - **State:** Mitigated
 - **CR20. Countermeasure name:** Enforce MFA, use secure cookies, and invalidate sessions
 - **Status:** IMPLEMENTED

Use case: Repudiation

- CRT21. Threat name:** Attackers can evade detection without proper logging
- **Inherent risk:** Medium
 - **Current risk:** Very Low
 - **Projected risk:** Very Low
 - **State:** Mitigated
 - **CR21. Countermeasure name:** Capture and monitor detailed logs for critical actions
 - **Status:** IMPLEMENTED

Use case: Tampering

- CRT22. Threat name:** Attackers can inject malicious commands
- **Inherent risk:** High
 - **Current risk:** Very Low
 - **Projected risk:** Very Low
 - **State:** Mitigated
 - **CR22. Countermeasure name:** Implement prepared statements and validate user inputs
 - **Status:** IMPLEMENTED
- CRT23. Threat name:** Attackers can inject scripts
- **Inherent risk:** High
 - **Current risk:** Very Low
 - **Projected risk:** Very Low
 - **State:** Mitigated
 - **CR23. Countermeasure name:** Ensure proper escaping/encoding of dynamic content and configure CSP
 - **Status:** IMPLEMENTED

- CRT24. Threat name:** Attackers can manipulate business workflows
- **Inherent risk:** Critical

- **Current risk:**  Very Low
- **Projected risk:**  Very Low
- **State:** Mitigated
- **CR24. Countermeasure name:** Implement server-side checks and multi-step validation for important transactions
- **Status:** IMPLEMENTED

CRT25. Threat name: Attackers can run malicious code via deserialization

- **Inherent risk:**  Medium
- **Current risk:**  Very Low
- **Projected risk:**  Very Low
- **State:** Mitigated
- **CR25. Countermeasure name:** Use secure data formats and strict whitelisting for deserialization
- **Status:** IMPLEMENTED

Component: PostgreSQL Database

 **Use case:** Denial of Service

CRT26. Threat name: Attackers cause denial of service through resource exhaustion

- **Inherent risk:**  High
- **Current risk:**  Very Low
- **Projected risk:**  Very Low
- **State:** Mitigated
- **CR26. Countermeasure name:** Implement rate limiting and resource throttling
- **Status:** IMPLEMENTED

 **Use case:** Information Disclosure

CRT27. Threat name: Attackers exfiltrate data due to insecure backup procedures

- **Inherent risk:**  Critical
- **Current risk:**  Very Low
- **Projected risk:**  Very Low
- **State:** Mitigated
- **CR27. Countermeasure name:** Implement secure backup procedures with encryption and access controls
- **Status:** IMPLEMENTED

CRT28. Threat name: Attackers exploit misconfigurations in postgresql settings

- **Inherent risk:**  Critical
- **Current risk:**  Very Low
- **Projected risk:**  Very Low
- **State:** Mitigated
- **CR28. Countermeasure name:** Harden postgresql configuration and restrict network access
- **Status:** IMPLEMENTED

CRT29. Threat name: Attackers exploit sql injection vulnerabilities

- **Inherent risk:**  High
- **Current risk:**  Very Low
- **Projected risk:**  Very Low
- **State:** Mitigated
- **CR29. Countermeasure name:** Use parameterized queries and validate inputs
- **Status:** IMPLEMENTED

CRT30. Threat name: Attackers intercept data due to unencrypted communications

- **Inherent risk:**  High
- **Current risk:**  Very Low
- **Projected risk:**  Very Low
- **State:** Mitigated
- **CR30. Countermeasure name:** Enforce TLS encryption for all connections
- **Status:** IMPLEMENTED
- **CR31. Countermeasure name:** Encrypt data at rest using Transparent Data Encryption (TDE) or Volume-Level Encryption
- **Status:** IMPLEMENTED

 **Use case:** Tampering

CRT31. Threat name: Attackers exploit outdated postgresql vulnerabilities

- **Inherent risk:**  Critical
- **Current risk:**  Very Low
- **Projected risk:**  Very Low
- **State:** Mitigated
- **CR32. Countermeasure name:** Regularly update postgresql to the latest secure version
- **Status:** IMPLEMENTED
- **CR33. Countermeasure name:** Apply regular security patches and minor version updates
- **Status:** IMPLEMENTED

CRT32. Threat name: Attackers tamper with data due to insecure file permissions

- **Inherent risk:**  High

- **Current risk:**  Very Low
- **Projected risk:**  Very Low
- **State:** Mitigated
- **CR34. Countermeasure name:** Enforce secure file permissions on PostgreSQL database files
- **Status:** IMPLEMENTED

 Use case: Spoofing

- CRT33. Threat name:** Attackers gain unauthorized access due to weak authentication
- **Inherent risk:**  High
 - **Current risk:**  Medium
 - **Projected risk:**  Medium
 - **State:** Partly-Mitigated
 - **CR35. Countermeasure name:** Implement robust authentication and role-based access control
 - **Status:** IMPLEMENTED
 - **CR36. Countermeasure name:** Implement multi-factor authentication (MFA) using identity providers
 - **Status:** NOTAPPLICABLE

 Use case: Elevation of Privilege

- CRT34. Threat name:** Attackers misuse insider privileges
- **Inherent risk:**  Medium
 - **Current risk:**  Very Low
 - **Projected risk:**  Very Low
 - **State:** Mitigated
 - **CR37. Countermeasure name:** Enable comprehensive auditing and logging of database activity
 - **Status:** IMPLEMENTED

Component: Student Mobile/Web Client

 Use case: Information Disclosure

- CRT35. Threat name:** Data leakage via insecure backup or synchronization services
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR38. Countermeasure name:** Implement secure backup and data synchronization protocols
 - **Status:** NOTAPPLICABLE
- CRT36. Threat name:** Device theft or loss leading to data compromise
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR39. Countermeasure name:** Enable remote wipe and tracking features
 - **Status:** NOTAPPLICABLE
- CRT37. Threat name:** Exposure of sensitive data due to insecure local storage
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR40. Countermeasure name:** Implement secure data storage and device encryption
 - **Status:** NOTAPPLICABLE
- CRT38. Threat name:** Interception of network communications
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR41. Countermeasure name:** Use VPN and enforce encrypted communication channels
 - **Status:** NOTAPPLICABLE
- CRT39. Threat name:** Malware infections on the mobile device
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR42. Countermeasure name:** Deploy mobile anti-malware solutions
 - **Status:** NOTAPPLICABLE

 Use case: Tampering

- CRT40. Threat name:** Exploitation of unpatched mobile OS vulnerabilities

- **Inherent risk:**  High
- **Current risk:**  High
- **Projected risk:**  High
- **State:** Exposed
- **CR43. Countermeasure name:** Configure automatic mobile OS updates
 - **Status:** NOTAPPLICABLE

- CRT41. Threat name:** Infiltration of malicious applications
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR44. Countermeasure name:** Enforce app store whitelisting and robust app vetting
 - **Status:** NOTAPPLICABLE

 Use case: Elevation of Privilege

- CRT42. Threat name:** Exploitation of vulnerabilities in installed apps
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  Very Low
 - **State:** Exposed
 - **CR45. Countermeasure name:** Enforce regular app updates and conduct vulnerability scanning
 - **Status:** REQUIRED

 Use case: Spoofing

- CRT43. Threat name:** Phishing attacks targeting mobile users
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Critical
 - **State:** Exposed
 - **CR46. Countermeasure name:** Deploy mobile anti-phishing protection
 - **Status:** NOTAPPLICABLE
- CRT44. Threat name:** Unauthorized access due to weak device authentication
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  High
 - **State:** Exposed
 - **CR47. Countermeasure name:** Implement strong device authentication
 - **Status:** NOTAPPLICABLE

Component: Teacher Web Client

 Use case: Spoofing

- CRT45. Threat name:** Clickjacking
- **Inherent risk:**  Critical
 - **Current risk:**  Critical
 - **Projected risk:**  Very Low
 - **State:** Exposed
 - **CR48. Countermeasure name:** Detect and block UI redressing attempts
 - **Status:** REQUIRED

 Use case: Tampering

- CRT46. Threat name:** Client-side insecure data storage
- **Inherent risk:**  Critical
 - **Current risk:**  Very Low
 - **Projected risk:**  Very Low
 - **State:** Mitigated
 - **CR49. Countermeasure name:** Prevent storage of sensitive data on the client
 - **Status:** IMPLEMENTED
- CRT47. Threat name:** Cross-site scripting
- **Inherent risk:**  High
 - **Current risk:**  High
 - **Projected risk:**  Very Low
 - **State:** Exposed
 - **CR50. Countermeasure name:** Avoid unsafe DOM manipulation and isolate untrusted scripts
 - **Status:** REQUIRED
- CRT48. Threat name:** Man-in-the-middle attacks
- **Inherent risk:**  High
 -

- **Current risk:**  Very Low
- **Projected risk:**  Very Low
- **State:** Mitigated
- **CR51. Countermeasure name:** Ensure secure communication and validate external resources
 - **Status:** IMPLEMENTED

End of Current Risk Report